

OpenSSF unveils repository to combat malicious open source packages

Open Source Security Foundation (OpenSSF) is taking on malicious open source software by launching the 'Malicious Packages' repository. The aim is to streamline open source security and counter potential threats.

Caleb Brown, a senior software engineer at the Google Open Source Security Team, and Jossef Harush Kadouri, head of software supply chain security at Checkmarx, highlighted the current complexities in dealing with malicious open



source packages. Multiple open source package repositories handle such packages in unique ways, often leading to a convoluted process. Typically, when the

community reports a malicious package, the package repository's security team removes it along with its metadata. Unfortunately, these actions usually occur without a trace or public record.

This fragmented approach has made identifying and tracking malicious packages a challenge, necessitating extensive data gathering from various public sources or reliance on proprietary threat intelligence feeds.

OpenSSF's Malicious Packages repository acts as a central hub, where reports of malicious open source packages are stored and accessible to the wider community. The repository simplifies the process of tracking, identifying, and countering threats within the open source ecosystem.

Brown and Kadouri emphasised the repository's significance, stating, "OpenSSF believes that having a public repository of this information will 'stop malicious dependencies from moving through CI/CD pipelines, refine detection engines, scan for and prevent usage in environments, or accelerate incident response'."

A noteworthy feature of the repository is its use of the open source vulnerability (OSV) format for report storage, ensuring compatibility with various tools such as the osv.dev API, the osv-scanner tool, and deps.dev.

The repository compiles data from diverse sources, including Checkmarx security, exports of malicious packages tracked by GitHub, and the Package Analysis project. This detailed behavioural analysis helps to determine whether a package displays malicious traits.

AMD to acquire Indian-founded Nod.ai, bolstering AI portfolio

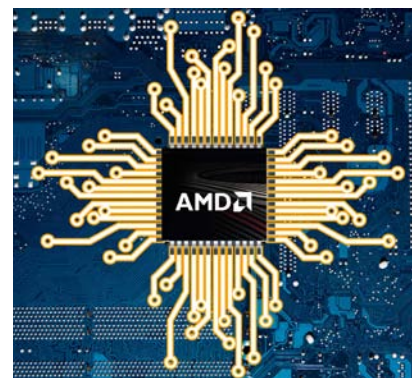
Advanced Micro Devices, Inc. (AMD), the Californian semiconductor giant, has sealed the deal to acquire Nod.ai, an open source AI software startup co-founded by Anush Elangovan and Harsh Menon, marking a pivotal step towards enhancing its foothold in the AI domain.

Nod.ai, established in 2013, has been making waves with its expertise in machine intelligence, simplifying the training and deployment of machine learning models using advanced compiler and code generation technologies.

Vamsi Boppana, senior vice president of AMD's Artificial Intelligence Group, emphasised the significance of this acquisition, stating, "The acquisition of Nod.ai is expected to significantly enhance our ability to provide AI customers with open software that allows them to easily deploy highly performant AI models tuned for AMD hardware."

Nod.ai's software, notably SHARK, is designed to automate the deployment of high-performance AI models across various platforms, effectively reducing the need for manual optimisation. Anush Elangovan, CEO of Nod.ai, underscored their commitment to addressing the ever-evolving challenges in the industry. "By joining forces with AMD, we will bring this expertise to a broader range of customers on a global scale," he said.

This strategic move aligns with AMD's commitment to building a comprehensive open software ecosystem, facilitating the deployment of AI solutions. Nod.ai's technology is already widely utilised in cloud, edge, and endpoint devices.



The acquisition of Nod.ai signifies a significant development in AMD's AI growth strategy, underlining their focus on making AI solutions more accessible through developer tools, libraries, and models.

This landmark deal comes a year after AMD's acquisition of Xilinx, Inc., for \$50 billion, solidifying its position in the semiconductor industry.



For more news, visit www.opensourceforu.com